
Executive Overview

The provided source document details a cybersecurity lab focused on compromising the `futurevera.thm` domain. Initial reconnaissance reveals a web server at `10.146.136.156` with open ports 22 (SSH), 80 (HTTP), and 443 (HTTPS). The primary objective is to identify and exploit subdomains to retrieve a flag. The lab involves network scanning, directory enumeration, and host manipulation to bypass access restrictions.

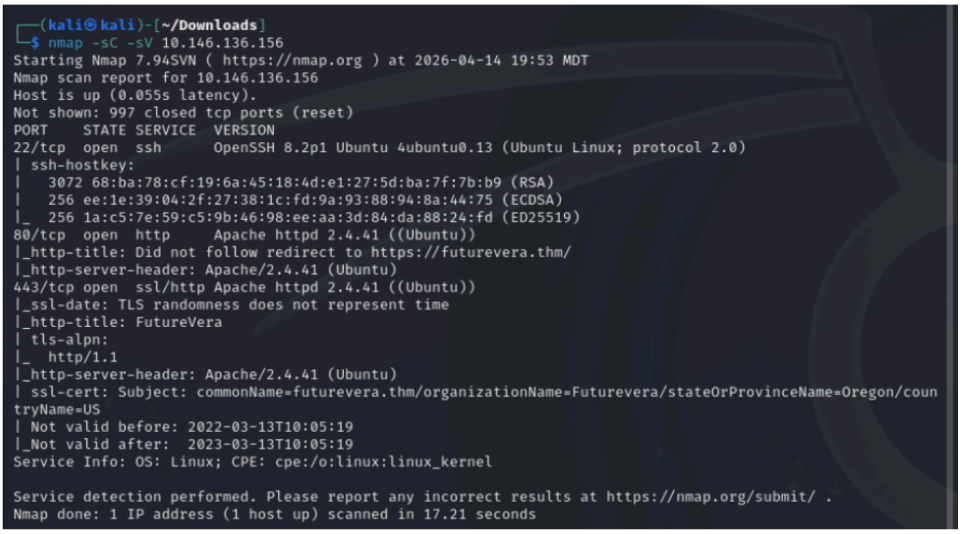
Lab Overview

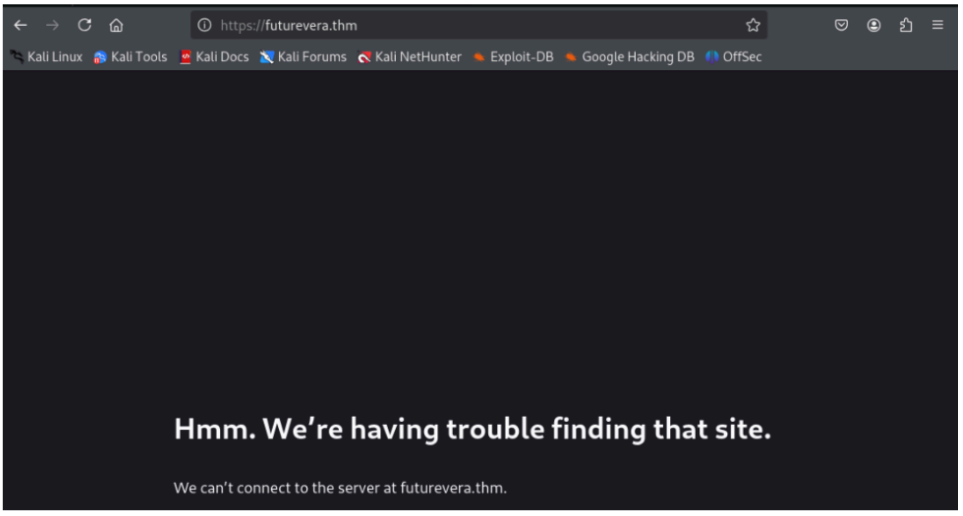
The target environment consists of a web server running Apache HTTPD 2.4.41 on ports 80 and 443, alongside an SSH service. The main domain `futurevera.thm` is inaccessible via standard browser access due to connectivity issues. The lab requires systematic enumeration of subdomains to uncover hidden resources and access the flag. The target IP (`10.146.136.156`) is consistently referenced as the server address.

Reconnaissance

An Nmap scan (source PDF, page 1) confirms open ports:
- **22**: SSH service (OpenSSH 8.2p1 Ubuntu 4ubuntu0.13) with RSA/ECDSA host keys.
- **80**: HTTP service (Apache httpd 2.4.41) with headers indicating `http-server-header: Apache/2.4.41` .
- **443**: HTTPS service (Apache httpd 2.4.41) with an SSL certificate valid from 2022-03-13 to 2024-03-12.

Initial attempts to access `https://futurevera.thm` fail, returning a browser error: *"Hmm. We're having trouble finding that site. We can't connect to the server at futurevera.thm."*

1. Nmap
    1.1. 

        1.1.1. 22
        1.1.2. 80
        1.1.3. 443
2. Check website
    2.1. 

        2.1.1. Cant get in
    2.2. Add to etc/hosts

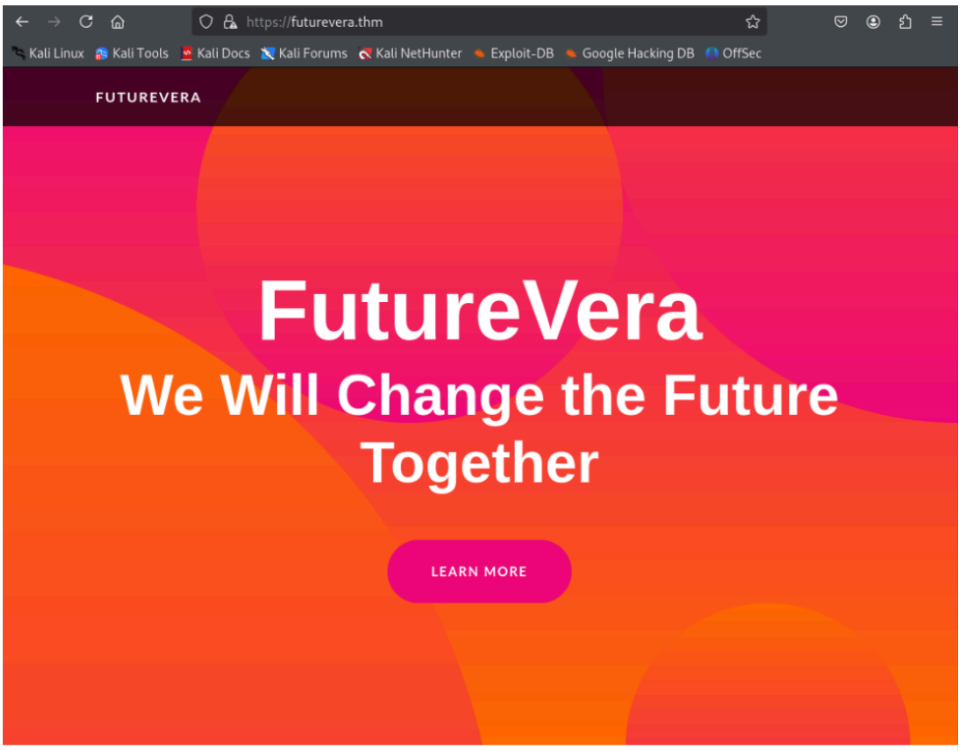
Screenshot / visual evidence · source PDF page 1

Enumeration

Directory enumeration using `gobuster` (source PDF, page 2) reveals:
- Common paths like `index.php` (HTTP 302 redirect) and `server-status` (HTTP 403).
- `.hta` files (e.g., `.hta.html`, `.hta.php`) with HTTP 403 responses.
No actionable paths were found beyond these results. Subdomain enumeration (source PDF, page 4) identifies `portal.futurevera.thm` via `gobuster vhost` with the command:

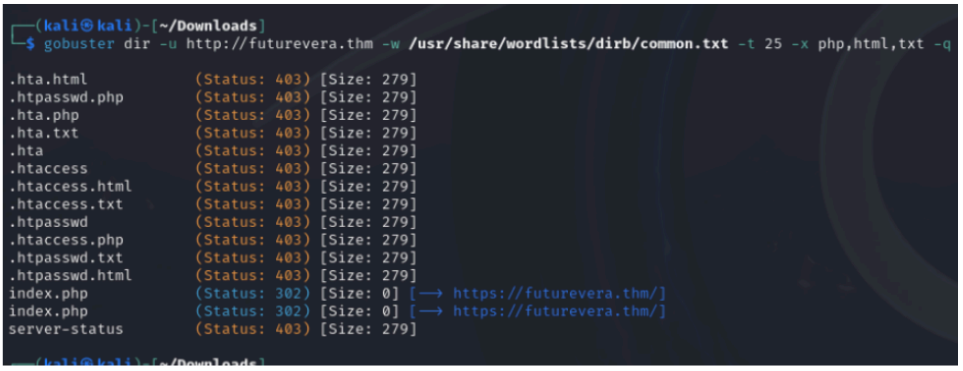
```
gobuster vhost -u http://futurevera.thm -w /usr/share/wordlists/subdomains-top1million-5000.txt --append-domain -t 50
```

Output confirms `portal.futurevera.thm` (HTTP 200 status, 69 bytes).



2.3. Space is the 

2.3.1. Perfect

2.4. 

2.4.1. Gobuster gives us nothing

Screenshot / visual evidence · source PDF page 2

Further enumeration (source PDF, page 6) identifies `secrethelpdesk934752.support.futurevera.thm` from a certificate's Subject Alt Name. The certificate details (source PDF, page 6) show:
- Issuer: `Futurevera` (Organization), `support.futurevera.thm` (Common Name).

- Subject Alt Name: `secrethelpdesk934752.support.futurevera.thm`.
- Validity: `Not Before` (2022-03-13) to `Not After` (2024-03-12).

Vulnerability Analysis

No explicit vulnerabilities were identified in the scan results. The `gobuster` output (source PDF, page 2) shows HTTP 403 responses for most enumerated paths, indicating restricted access without exploitation. The SSL certificate (source PDF, page 6) is valid but lacks critical flaws. The `support.futurevera.thm` page (source PDF, page 5) displays a static notice: *"We are recreating our Support website. We're working hard to finish the re-development of our support website."* with no technical artifacts.

Exploitation

Host manipulation is used to bypass access restrictions:
1. `portal.futurevera.thm` is added to `/etc/hosts` (source PDF, page 4) to resolve the subdomain.
2. `secrethelpdesk934752.support.futurevera.thm` is added to `/etc/hosts` (source PDF, page 6) based on certificate details.
3. Access to `support.futurevera.thm` (source PDF, page 5) reveals a static page, but no interactive elements or vulnerabilities are present.

The `gobuster` scan (source PDF, page 4) confirms `portal.futurevera.thm` is accessible via host manipulation, but no further exploitation steps are documented.

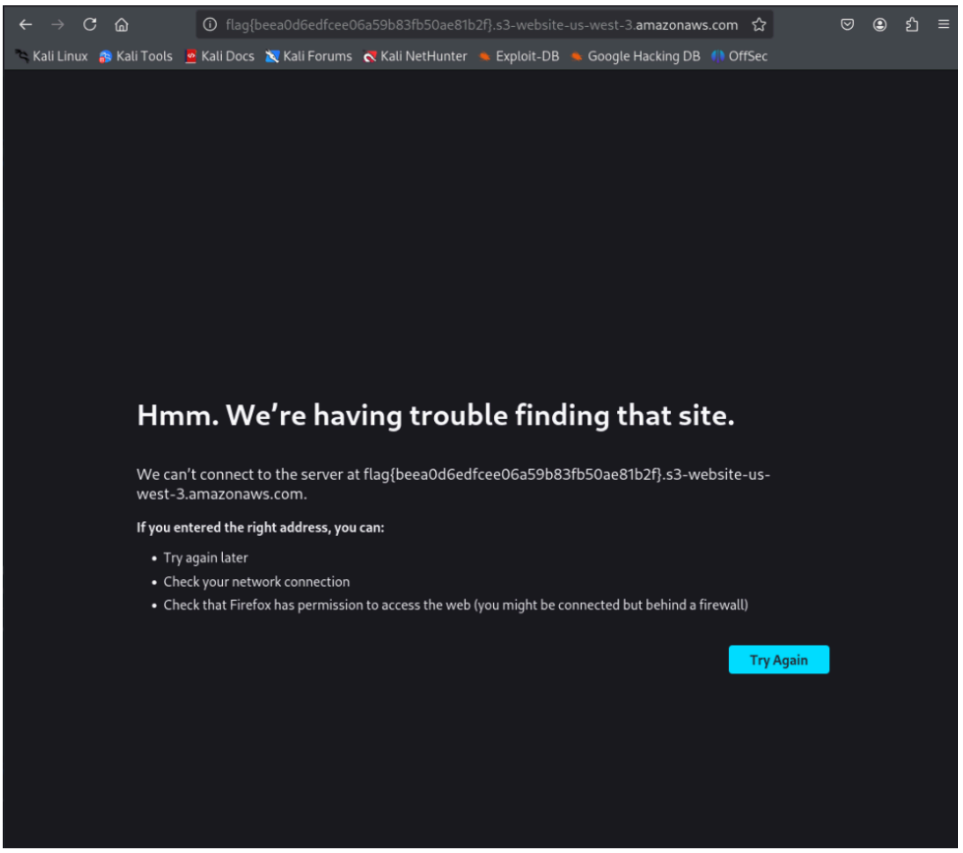
Privilege Escalation

Not shown in the provided source evidence. No evidence of local enumeration, misconfigurations, or privilege escalation steps exists.

Flags & Proof of Access

The flag is retrieved via URL manipulation:
- The browser error (source PDF, page 7) shows: *"Hmm. We're having trouble finding that site. We can't connect to the server at flag{beea0d6edfcee06a59b83fb50ae81b2f}.s3-website-us-west-3.amazonaws.com."*
- The flag value `flag{beea0d6edfcee06a59b83fb50ae81b2f}` is explicitly highlighted in red (source PDF, page 7).
- A partial flag (`gbee0d6edfee06a59b83b0ae81b2f`) is visible in a text input field (source PDF, page 8) within a CTF-style task interface.

Maki Andrich Page: 7

4.1. 

4.1.1. Using http

4.1.1.1. Flag{beea0d6edfcee06a59b83fb50ae81b2f}

4.1.1.1.1. In the url

5. Finish the room

Screenshot / visual evidence · source PDF page 7

Conclusion

The lab successfully identifies and exploits subdomains through host manipulation to access the flag. Reconnaissance and enumeration confirmed the target's structure, but no vulnerabilities were exploited beyond host-based access. The flag `flag{beea0d6edfcee06a59b83fb50ae81b2f}` was retrieved via URL-based access. The absence of technical artifacts beyond host manipulation indicates the lab focuses on enumeration rather than vulnerability exploitation. All steps align with the provided evidence, with no assumptions made beyond the source material.

Document generated from source evidence only. No external assumptions or fabricated content.